

```

<?php
// pages/cajero.php
require_once __DIR__ . '/../config.php';

if (!isset($_SESSION['usuario'])) {
    header("Location: ../index.html");
    exit;
}

$usuarioLogueado = $_SESSION['usuario'];
$puedeRetirar = !empty($usuarioLogueado['puede_retirar']) ||
strtoupper($usuarioLogueado['rol'] ?? '') === 'ADMIN';
?>
<!DOCTYPE html>
<html lang="es">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Banco Escolar - Módulo de Cajero</title>
    <link rel="stylesheet" href="../css/cajero.css">
    <link rel="stylesheet" href="../css/lector-qr.css">
    <style>
        .panel-cajero-grid {
            display: grid;
            grid-template-columns: 280px 1fr 320px;
            gap: 20px;
        }
        @media (max-width: 1100px) {
            .panel-cajero-grid { grid-template-columns: 1fr; }
        }
    </style>
</head>
<body>
    <?php include_once __DIR__ . '/../includes/navbar.php'; ?>

    <main class="dashboard-container">
        <!-- Buscador Superior -->
        <section class="card card-busqueda mb-4">
            <h2>Buscar Cuenta de Cliente</h2>
            <div class="search-box">
                <input type="text" id="txtBuscarDni" placeholder="Escaneá la
tarjeta QR o ingresá el DNI..." autofocus>
                <button id="btnBuscar" class="btn btn-primary">Buscar</button>
                <button id="btnEscanearQR" class="btn btn-dark">Cámara QR</button>
            </div>
        </section>

        <!-- PANEL EN 3 COLUMNAS: PERFIL | OPERACIONES (CENTRO) | MOVIMIENTOS
(DERECHA) -->
        <div id="panelAlumno" class="panel-cajero-grid" style="display: none;">

```

```

<!-- COLUMN 1: FICHA Y SALDO -->
<div class="columna-perfil">
    <section class="card card-perfil text-center">
        <div class="avatar-container mb-2">
            <img id="imgAlumno" src="" alt="Foto perfil" style="width:
100px; height: 100px; border-radius: 50%;">
        </div>
        <h3 id="lblNombre" class="mb-1">-</h3>
        <p id="lblCurso" class="text-muted mb-3">-</p>
        <div class="meta-info text-start small mb-3">
            <p class="mb-1"><strong>DNI:</strong> <span
id="lblDni"></span></p>
            <p class="mb-0"><strong>QR:</strong> <span
id="lblQR"></span></p>
        </div>
        <div class="saldo-box p-3 bg-light rounded">
            <span class="saldo-label text-uppercase small
text-muted">Saldo Actual</span>
            <h2 id="lblSaldo" class="text-success m-0">$0.00</h2>
        </div>
    </section>
</div>

<!-- COLUMN 2: ACCIONES PRINCIPALES (CENTRO) -->
<div class="columna-operaciones d-flex flex-column gap-3">
    <!-- Acreditar -->
    <section class="card card-recarga">
        <h3>🏧 Acreditar Dinero (Efectivo)</h3>
        <form id="formRecarga" class="mt-2">
            <div class="form-group mb-2">
                <label for="montoRecarga">Monto a cargar ($)</label>
                <input type="number" id="montoRecarga"
class="form-control" min="1" step="0.5" placeholder="Ej: 500.00" required>
            </div>
            <button type="submit" class="btn btn-success
w-100">Acreditar Saldo</button>
        </form>
    </section>

    <!-- Extraer -->
    <?php if ($puedeRetirar): ?>
    <section class="card card-extraccion" id="secExtraccion">
        <h3>🏧 Extracción / Retiro de Efectivo</h3>
        <form id="formExtraccion" class="mt-2">
            <div class="form-group mb-2">
                <label for="montoExtraccion">Monto a retirar
($)</label>
                <input type="number" id="montoExtraccion"
class="form-control" min="1" step="0.5" placeholder="Ej: 200.00" required>

```

```

        </div>
        <div class="form-group mb-3">
            <label for="pinExtraccion">PIN del Cliente</label>
            <input type="password" id="pinExtraccion"
class="form-control" maxlength="4" placeholder="*****" required>
        </div>
        <button type="submit" class="btn btn-danger
w-100">Confirmar Extracción</button>
        </form>
    </section>
    <?php endif; ?>

    <!-- Restaurar PIN -->
    <section class="card card-pin">
        <h3>🔒 Blanqueo / Restauración de PIN</h3>
        <form id="formResetPin" class="mt-2">
            <div class="form-group mb-3">
                <label for="nuevoPin">Nuevo PIN (4 dígitos)</label>
                <input type="password" id="nuevoPin"
class="form-control" maxlength="4" placeholder="*****" required>
            </div>
            <button type="submit" class="btn btn-warning
w-100">Restaurar PIN</button>
        </form>
    </section>
</div>

    <!-- COLUMNA 3: ULTIMOS MOVIMIENTOS (DERECHA) -->
    <div class="columna-movimientos">
        <section class="card h-100">
            <div class="d-flex justify-content-between align-items-center
mb-3">
                <h4 class="m-0">Últimos Movimientos</h4>
                <button type="button" class="btn btn-sm
btn-outline-secondary" onclick="cargarUltimosMovimientos()">🔄</button>
            </div>
            <div class="tabla-movimientos-container" style="max-height:
480px; overflow-y: auto;">
                <table class="tabla-movimientos w-100">
                    <thead>
                        <tr>
                            <th>Fecha</th>
                            <th>Tipo</th>
                            <th>Monto</th>
                        </tr>
                    </thead>
                    <tbody id="tblMovimientosBody">
                        <tr><td colspan="3" class="text-center
text-muted">A la espera...</td></tr>
                    </tbody>
                </table>
            </div>
        </section>
    </div>

```

```

        </table>
    </div>
</section>
</div>

```

```

</div>
</main>

```

```

<script src="https://unpkg.com/html5-qrcode"></script>
<script src="../../js/lectorQR.js"></script>
<script src="../../js/cajero.js"></script>
</body>
</html>

```

```

// js/cajero.js

```

```

let alumnoActual = null;

```

```

document.addEventListener('DOMContentLoaded', () => {
    document.getElementById('btnBuscar')?.addEventListener('click', () => {
        const q = document.getElementById('txtBuscarDni').value.trim();
        if (q) buscarAlumno(q);
    });

    document.getElementById('txtBuscarDni')?.addEventListener('keypress', (e) => {
        if (e.key === 'Enter') {
            const q = e.target.value.trim();
            if (q) buscarAlumno(q);
        }
    });
});

```

```

// Bindeo del botón Cámara QR usando el modal unificado

```

```

document.getElementById('btnEscanearQR')?.addEventListener('click', () => {
    abrirLectorQR((codigoLeido) => {
        const inputDni = document.getElementById('txtBuscarDni');
        if (inputDni) {
            inputDni.value = codigoLeido;
        }
        buscarAlumno(codigoLeido); // Llama directo a la búsqueda tras cerrar el
modal
    });
});

document.getElementById('formRecarga')?.addEventListener('submit',
procesarRecarga);
document.getElementById('formExtraccion')?.addEventListener('submit',
procesarExtraccion);
document.getElementById('formResetPin')?.addEventListener('submit',
procesarResetPin);
});

```

```

async function buscarAlumno(criterio) {

```

```

    try {
        const res = await
fetch(`../procesar_cajero.php?accion=buscar_alumno&criterio=${encodeURIComponent(criterio)}`);
        const data = await res.json();

        if (!data.success) {
            alert(data.message || "Cliente no encontrado.");
            document.getElementById('panelAlumno').style.display = 'none';
            alumnoActual = null;
            return;
        }

        alumnoActual = data.alumno;
        document.getElementById('lblNombre').innerText =
alumnoActual.nombre_apellido;
        document.getElementById('lblCurso').innerText = alumnoActual.curso || 'Sin
curso';
        document.getElementById('lblDni').innerText = alumnoActual.dni;
        document.getElementById('lblQR').innerText = alumnoActual.codigo_qr || 'Sin
QR';
        document.getElementById('lblSaldo').innerText =
`$${Number(alumnoActual.saldo || 0).toFixed(2)}`;

        const fotoDefault = "data:image/svg+xml;utf8,<svg
xmlns='http://www.w3.org/2000/svg' width='100' height='100' viewBox='0 0 24 24'
fill='none' stroke='%23a0aec0'><circle cx='12' cy='7' r='4'/></svg>";
        document.getElementById('imgAlumno').src = alumnoActual.foto_url ||
fotoDefault;
        document.getElementById('panelAlumno').style.display = 'grid';

        await cargarUltimosMovimientos();
    } catch (err) {
        console.error("Error en buscarAlumno:", err);
        alert("Error al conectar con el servidor.");
    }
}

```

```

async function cargarUltimosMovimientos() {
    if (!alumnoActual) return;
    const tbody = document.getElementById('tblMovimientosBody');
    tbody.innerHTML = `<tr><td colspan="3" class="text-center
text-muted">Cargando...</td></tr>`;

    try {
        const res = await
fetch(`../procesar_cajero.php?accion=movimientos&alumno_id=${alumnoActual.id}`);
        const data = await res.json();

        if (!data.success || !data.movimientos || data.movimientos.length === 0) {

```

```

        tbody.innerHTML = `|  |  |  |  |  |  |
| --- | --- | --- | --- | --- | --- |
| | | | | | |

```

```

        alert(data.message);
        if (data.success) {
            alumnoActual.saldo = data.nuevo_saldo;
            document.getElementById('lblSaldo').innerText =
`$$${Number(data.nuevo_saldo).toFixed(2)}`;
            document.getElementById('formRecarga').reset();
            await cargarUltimosMovimientos();
        }
    } catch (err) {
        alert("Error al procesar la acreditación.");
    }
}

async function procesarExtraccion(e) {
    e.preventDefault();
    if (!alumnoActual) return;

    const monto = parseFloat(document.getElementById('montoExtraccion').value);
    const pin = document.getElementById('pinExtraccion').value;

    if (isNaN(monto) || monto <= 0) return alert("Monto no válido");

    try {
        const res = await fetch('../procesar_cajero.php', {
            method: 'POST',
            headers: { 'Content-Type': 'application/json' },
            body: JSON.stringify({ accion: 'extraer', alumno_id: alumnoActual.id,
monto, pin })
        });
        const data = await res.json();

        alert(data.message);
        if (data.success) {
            alumnoActual.saldo = data.nuevo_saldo;
            document.getElementById('lblSaldo').innerText =
`$$${Number(data.nuevo_saldo).toFixed(2)}`;
            document.getElementById('formExtraccion').reset();
            await cargarUltimosMovimientos();
        }
    } catch (err) {
        alert("Error al procesar la extracción.");
    }
}

async function procesarResetPin(e) {
    e.preventDefault();
    if (!alumnoActual) return;

    const nuevoPin = document.getElementById('nuevoPin').value.trim();

```

```

    try {
        const res = await fetch('../procesar_cajero.php', {
            method: 'POST',
            headers: { 'Content-Type': 'application/json' },
            body: JSON.stringify({ accion: 'reset_pin', alumno_id: alumnoActual.id,
nuevo_pin: nuevoPin })
        });
        const data = await res.json();

        alert(data.message);
        if (data.success) {
            document.getElementById('formResetPin').reset();
        }
    } catch (err) {
        alert("Error al intentar cambiar el PIN.");
    }
}

```

```

<?php
// procesar_cajero.php
header('Content-Type: application/json');
require_once __DIR__ . '/config.php';

// Control de Sesión
if (!isset($_SESSION['usuario'])) {
    echo json_encode(['success' => false, 'message' => 'Sesión expirada o no
autorizada.']);
    exit;
}

$usuarioLogueado = $_SESSION['usuario'];
$input = json_decode(file_get_contents('php://input'), true) ?? [];
$accion = $input['accion'] ?? ($_GET['accion'] ?? '');

try {
    switch ($accion) {

        // 1. BUSCAR ALUMNO
        case 'buscar_alumno':
            $query = trim($_GET['criterio'] ?? '');
            if (empty($query)) throw new Exception("Ingrese un DNI o código QR.");

            $endpoint = "alumnos?or=(dni.eq." . urlencode($query) .
",codigo_qr.eq." . urlencode($query) . ")";
            $res = supabaseQuery($endpoint, 'GET');

            if (empty($res) || isset($res['error']) || isset($res['code'])) {
                echo json_encode(['success' => false, 'message' => 'Alumno no
encontrado.']);
            }

```

```

        exit;
    }

    $alumno = $res[0];
    unset($alumno['pin']); // No exponemos la clave en el cliente

    echo json_encode(['success' => true, 'alumno' => $alumno]);
    break;

// 2. ULTIMOS MOVIMIENTOS
case 'movimientos':
    $alumnoId = trim($_GET['alumno_id'] ?? '');
    if (empty($alumnoId)) throw new Exception("ID de alumno no provisto.");

    $endpoint = "transacciones?alumno_id=eq." . urlencode($alumnoId) .
"&order=fecha_hora.desc&limit=10";
    $movs = supabaseQuery($endpoint, 'GET');

    if (is_array($movs) && isset($movs['code'])) {
        echo json_encode([
            'success' => false,
            'message' => 'Error en base de datos: ' . ($movs['message'] ??
'Error de consulta'),
            'movimientos' => []
        ]);
        exit;
    }

    echo json_encode(['success' => true, 'movimientos' => is_array($movs) ?
$movs : []]);
    break;

// 3. ACREDITAR DINERO
case 'acreditar':
    $alumnoId = trim($input['alumno_id'] ?? '');
    $monto = floatval($input['monto'] ?? 0);
    if ($monto <= 0) throw new Exception("Monto inválido.");

    $resAl = supabaseQuery("alumnos?id=eq." . urlencode($alumnoId), 'GET');
    if (empty($resAl) || isset($resAl['code']) || empty($resAl[0])) throw
new Exception("Alumno no encontrado.");
    $alumno = $resAl[0];

    $nuevoSaldo = floatval($alumno['saldo'] ?? 0) + $monto;

    // Actualizar Saldo
    supabaseQuery("alumnos?id=eq." . urlencode($alumnoId), 'PATCH',
['saldo' => $nuevoSaldo]);

    // Insertar Transacción

```

```

$dataTx = [
    'alumno_id' => $alumnoId,
    'monto'      => $monto,
    'tipo'       => 'RECARGA',
    'estado'     => 'OK',
    'fecha_hora' => date('c')
];

if (!empty($usuarioLogueado['id'])) {
    $dataTx['usuario_banco_id'] = (int)$usuarioLogueado['id'];
}

supabaseQuery("transacciones", 'POST', $dataTx);

registrarAuditoria('RECARGA', $usuarioLogueado['usuario'] ?? 'CAJERO',
$alumno['dni'], "Carga de saldo presencial: \${$monto}");

echo json_encode(['success' => true, 'nuevo_saldo' => $nuevoSaldo,
'message' => "¡Carga exitosa! Nuevo saldo: \${$nuevoSaldo}"]);
break;

// 4. EXTRAER DINERO
case 'extraer':
    $puedeRetirar = !empty($usuarioLogueado['puede_retirar']) ||
strtoupper($usuarioLogueado['rol'] ?? '') === 'ADMIN';
    if (!$puedeRetirar) throw new Exception("No tiene permisos para
realizar extracciones.");

    $alumnoId = trim($input['alumno_id'] ?? '');
    $monto = floatval($input['monto'] ?? 0);
    $pinInput = trim($input['pin'] ?? '');

    if ($monto <= 0) throw new Exception("Monto inválido.");

    $resAl = supabaseQuery("alumnos?id=eq." . urlencode($alumnoId), 'GET');
    if (empty($resAl) || isset($resAl['code']) || empty($resAl[0])) throw
new Exception("Alumno no encontrado.");
    $alumno = $resAl[0];

    $saldoActual = floatval($alumno['saldo'] ?? 0);
    if ($monto > $saldoActual) throw new Exception("Fondos insuficientes.
Saldo actual: \${$saldoActual}");

    // Validar PIN (soporta tanto hash bcrypt como texto plano)
    $pinDB = (string)$alumno['pin'] ?? '';
    $pinOk = password_verify($pinInput, $pinDB) || ($pinInput === $pinDB);

    if (!$pinOk) {
        registrarAuditoria('INTENTO_FALLIDO_PIN',
$usuarioLogueado['usuario'] ?? 'CAJERO', $alumno['dni'], "Fallo de PIN en intento

```

```

de extracción de \${$monto}");
        throw new Exception("PIN incorrecto.");
    }

    $nuevoSaldo = $saldoActual - $monto;

    // Actualizar Saldo
    supabaseQuery("alumnos?id=eq." . urlencode($alumnoId), 'PATCH',
['saldo' => $nuevoSaldo]);

    // Insertar Transacción
    $dataTx = [
        'alumno_id' => $alumnoId,
        'monto'      => $monto,
        'tipo'       => 'EXTRACCION',
        'estado'     => 'OK',
        'fecha_hora' => date('c')
    ];

    if (!empty($usuarioLogueado['id'])) {
        $dataTx['usuario_banco_id'] = (int)$usuarioLogueado['id'];
    }

    supabaseQuery("transacciones", 'POST', $dataTx);

    registrarAuditoria('EXTRACCION', $usuarioLogueado['usuario'] ??
'CAJERO', $alumno['dni'], "Extracción en efectivo: \${$monto}");

    echo json_encode(['success' => true, 'nuevo_saldo' => $nuevoSaldo,
'message' => "¡Extracción autorizada! Entregar \${$monto}."]);
    break;

// 5. RESTAURAR PIN
case 'reset_pin':
    $alumnoId = trim($input['alumno_id'] ?? '');
    $nuevoPin = trim($input['nuevo_pin'] ?? '');

    if (strlen($nuevoPin) !== 4 || !is_numeric($nuevoPin)) {
        throw new Exception("El PIN debe contener exactamente 4 números.");
    }

    $pinHash = password_hash($nuevoPin, PASSWORD_BCRYPT);

    supabaseQuery("alumnos?id=eq." . urlencode($alumnoId), 'PATCH', ['pin'
=> $pinHash]);

    registrarAuditoria('BLANQUEO_PIN', $usuarioLogueado['usuario'] ??
'CAJERO', $alumnoId, "Blanqueo y cambio de PIN de alumno");

    echo json_encode(['success' => true, 'message' => '¡PIN actualizado

```

```

exitosamente!']);
    break;

    default:
        echo json_encode(['success' => false, 'message' => 'Acción no
válida.']);
        break;
    }
} catch (Exception $e) {
    echo json_encode(['success' => false, 'message' => $e->getMessage()]);
}

<?php
// C:\xampp\htdocs\eBank\config.php
session_start();

define('SUPABASE_URL', 'https://hkxigkizqedbirytsrmb.supabase.co');
define('SUPABASE_KEY',
'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSI6ImhreGlna2l6cWVhYmlyeXRzcm1iIiwicm9sZSI6ImFub24iLCJpYXQiOiE3ODY1MTIzNzEsImV4cCI6MjEwMjE0ODM3MX0.DLgrW2Z-32cJljfV0MYUKsxKcsG2C0WFI58KTVIQXJU');

// QR Maestro oculto en el servidor
define('QR_MAESTRO_ADMIN', '1'); //ObiWanKenobi

// imgBB key
define('IMGBB_API_KEY', '61a76cc12d06bd22948b4b5b76f5b45e');
/**
 * Función global para hacer consultas a la API REST de Supabase mediante CURL
 */
function supabaseQuery($endpoint, $method = 'GET', $data = null) {
    $url = SUPABASE_URL . '/rest/v1/' . $endpoint;

    $headers = [
        'apikey: ' . SUPABASE_KEY,
        'Authorization: Bearer ' . SUPABASE_KEY,
        'Content-Type: application/json',
        'Prefer: return=representation'
    ];

    $ch = curl_init($url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_HTTPHEADER, $headers);

    // Desactivar verificación SSL solo para pruebas locales en XAMPP si CURL da
    problemas
    curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false);

```

```

// 1. Definimos explícitamente el método (GET, POST, PATCH, DELETE, etc.)
curl_setopt($ch, CURLOPT_CUSTOMREQUEST, strtoupper($method));

// 2. Si enviamos un Payload y NO es un GET, adjuntamos los datos JSON
if ($data !== null && strtoupper($method) !== 'GET') {
    curl_setopt($ch, CURLOPT_POSTFIELDS, json_encode($data));
}

$response = curl_exec($ch);

if (curl_errno($ch)) {
    $error_msg = curl_error($ch);
    curl_close($ch);
    return ['error' => $error_msg];
}

curl_close($ch);

return json_decode($response, true);
}

if (!function_exists('registrarAuditoria')) {
    function registrarAuditoria($tipoEvento, $usuarioOrigen, $usuarioDestino,
    $detalle = '') {
        $payload = [
            'tipo_evento'      => $tipoEvento,
            'usuario_origen'   => $usuarioOrigen,
            'usuario_destino'  => $usuarioDestino,
            'detalle'          => $detalle
        ];
        return supabaseQuery('logs_auditoria', 'POST', $payload);
    }
}

```